

SAST / Dependency Security Scanning Evidence

Application: **CHT Platform SDK** · Organization: **Community Health Media**

1. Summary

CHT Platform undergoes **static / dependency security scanning** on a recurring schedule via GitHub Actions. Scans include npm dependency audit (backend and frontend) and Aquasecurity **Trivy** filesystem scans (backend and worker). This constitutes SAST-oriented and software composition analysis (SCA) coverage. **Dedicated commercial DAST** and **third-party penetration testing** are not claimed in this package.

2. Tooling

Tool	Type	Target
npm audit --audit-level=high	SCA / dependency	backend/, frontend/
Aquasecurity Trivy (fs)	SAST / SCA filesystem	backend/, worker/ — CRITICAL,HIGH

3. Cadence & automation

Workflow: **.github/workflows/security-monthly.yml** (“Monthly Security Scan”). Scheduled for the first Monday of each month (09:00 UTC). Runs on GitHub-hosted runners with contents:read and security-events:write permissions. Results are retained in GitHub Actions run history.

4. Workflow excerpt (as committed)

```
name: Monthly Security Scan
on:
  schedule:
    - cron: '0 9 1-7 * 1' # first Monday monthly

jobs:
  security:
    steps:
      - Backend/Frontend: npm ci
      - Backend: npm audit --audit-level=high
      - Frontend: npm audit --audit-level=high
      - Trivy fs scan: ./backend (severity CRITICAL,HIGH)
      - Trivy fs scan: ./worker (severity CRITICAL,HIGH)
```

5. Related build-time checks

Pull request validation (.github/workflows/pr-validation.yml) additionally enforces compile/typecheck and Terraform validate prior to merge into protected paths, reducing defective or misconfigured releases.

6. Remediation practice

High/critical findings from monthly scans are reviewed by engineering. Dependency updates are applied via normal PR process. Secrets and Zoom credentials are rotated through AWS Secrets Manager / GitHub Environments when required. Severity thresholds for Trivy remain CRITICAL/HIGH.

7. Attestation

This evidence reflects the security scanning configuration in the cht-platform-tool repository as of 2026-08-13. It does not assert SOC 2 certification, ISO 27001 certification, or completion of third-party penetration testing.